

اطلاعات مربوط به نام میزبان ها (Hostname Information)



- نام میزبان ها اغلب هدفشان را نشان می دهند.

جمع آوری اطلاعات زیرساخت (Recon - Infrastructure) :

- برای حمله Password Spraying. به دنبال نام میزبان هایی باشید که شامل موارد زیر هستند:
 - پورتال های ورود VPN : `access.vpn`
 - پورتال های Citrix StoreFront : `storefront.citrix.ctx`
 - ایمیل آنلاین : `owa.autodiscover.mail`
 - نام میزبان های حاوی کلمات `remote` یا `adfs.sso.portal.login` نیز اهداف خوبی هستند.

پس از تهیه لیست نام میزبان ها، می توانیم اولویت بندی کنیم که کدام میزبان ها را در مراحل بعدی زنجیره حمله هدف قرار دهیم.

- اولین نوع نام میزبان : آنهایی که شامل `vpn` هستند. اگر بتوانیم اعتبارنامه یک کاربر را حدس بزنیم و سرویس VPN با احراز هویت دومرحله ای (MFA) محافظت نشده باشد، در یک مرحله به شبکه داخلی دسترسی پیدا می کنیم.
- سرویس های Citrix : سرویس های Citrix برای میزبانی VPN ، دسکتاپ مجازی و دسترسی به برنامه های تک کاربره استفاده می شوند. حمله Password Spraying به Citrix می تواند منجر به دسترسی به اعتبارنامه های معتبر داخلی، دسترسی به شبکه VPN ، یا حتی دسترسی به یک سیستم متصل به دامنه

(Domain-Joined) داخل شبکه شود. همچنین، در صورت حمله به یک برنامه میزبانی شده در Citrix ، امکان **Breakout** (خروج از محیط Citrix) وجود دارد که می تواند دسترسی به اعتبارنامه های سطح بالا در شبکه داخلی را فراهم کند.

- **سرویس های ایمیل**: نام میزبان هایی مانند owa, autodiscover یا mail معمولاً به سرویس های Microsoft Exchange اشاره دارند. حمله به نقاط پایانی (Endpoints) این سرویس ها (مانند **Auto-Discover** و **Exchange Web Services (EWS)**) می تواند اعتبارنامه های دامنه داخلی را لو دهد که برای سایر سرویس های خارجی نیز کاربرد دارند.
- **سرویس های ADFS و SSO**: نام میزبان های حاوی sso, portal, login, adfs یا remote نشان دهنده سرویس های احراز هویت متمرکز (مانند **Single Sign-On (SSO)** یا **Active Directory Federated Services (ADFS)**) هستند. این سرویس ها به دلیل دسترسی به چندین سرویس دیگر، اهداف ارزشمندی محسوب می شوند. همچنین، نام میزبان های حاوی portal, login و remote نیز ارزش بررسی دارند، زیرا ممکن است نشان دهنده دسترسی VPN یا سایر سرویس های سازمانی باشند.

نکته ها

1. نام میزبان ها نشانگر سرویس ها:

- VPN → access پورتال های VPN
- citrix → ctx سرویس های Citrix
- owa → mail سرویس های ایمیل (Microsoft Exchange)
- adfs → sso, login سرویس های احراز هویت متمرکز

2. اولویت بندی اهداف:

- **VPN بدون MFA**: دسترسی مستقیم به شبکه داخلی.
- **Citrix**: دسترسی به اعتبارنامه های داخلی و سیستم های متصل به دامنه.
- **Microsoft Exchange**: نفوذ به ایمیل های سازمانی و اعتبارنامه های دامنه.
- **SSO/ADFS**: دسترسی به چندین سرویس با یک اعتبارنامه.

3. حمله Password Spraying:

- حمله با استفاده از لیستی از رمزهای عبور رایج روی چندین حساب کاربری.
- مؤثر در صورت نبودن قفل حساب (Account Lockout) یا MFA.

4. خطرات:

- دسترسی به شبکه داخلی از طریق VPN.
- استخراج اعتبارنامه های داخلی از سرویس های Citrix یا Exchange.
- سوءاستفاده از SSO برای نفوذ به چندین سرویس.

کاربرد اطلاعات نام میزبان‌ها (Hostname Information) برای هکرها و پنتسترها

اطلاعات مربوط به نام میزبان‌ها (Hostnames) می‌تواند برای هکرها و پنتسترها بسیار مفید باشد. در ادامه، کاربردهای این اطلاعات برای هر دو گروه را به طور جداگانه بررسی می‌کنیم:

1. کاربرد برای هکرها:

الف) شناسایی اهداف پریسک:

- هکرها از نام میزبان‌ها برای شناسایی سرویس‌های حیاتی مانند **VPN, Citrix, Microsoft Exchange** و **SSO/ADFS** استفاده می‌کنند.
- این سرویس‌ها معمولاً دسترسی مستقیم به شبکه داخلی یا اعتبارنامه‌های سازمانی را فراهم می‌کنند.

ب) اجرای حملات هدفمند:

- **Password Spraying**: هکرها با استفاده از نام میزبان‌هایی مانند **vpn.example.com** یا **mail.example.com** حملات **Password Spraying** را اجرا می‌کنند. این حمله شامل استفاده از رمزهای عبور رایج روی چندین حساب کاربری است.
- **نفوذ به شبکه داخلی**: اگر سرویس **VPN** بدون احراز هویت دومرحله‌ای (MFA) باشد، هکرها می‌توانند با حدس زدن یک رمز عبور، به شبکه داخلی دسترسی پیدا کنند.

ج) سوءاستفاده از سرویس‌های آسیب‌پذیر:

- **Citrix**: هکرها با نفوذ به سرویس‌های **Citrix** می‌توانند به اعتبارنامه‌های داخلی، شبکه **VPN**، یا حتی سیستم‌های متصل به دامنه دسترسی پیدا کنند.
- **Microsoft Exchange**: با حمله به سرویس‌های ایمیل (مانند **owa.example.com**) هکرها می‌توانند اعتبارنامه‌های دامنه داخلی را به دست آورند.
- **SSO/ADFS**: این سرویس‌ها به هکرها اجازه می‌دهند با یک اعتبارنامه به چندین سرویس دسترسی پیدا کنند.

د) Lateral Movement در شبکه:

- پس از نفوذ اولیه، هکرها از اطلاعات نام میزبان‌ها برای **Lateral Movement** در شبکه استفاده می‌کنند.

- به عنوان مثال، دسترسی به یک سیستم متصل به دامنه (Domain-Joined) می‌تواند به هکرها امکان دسترسی به سایر بخش‌های شبکه را بدهد.

2. کاربرد برای پنتسترها

الف) شناسایی سطح حمله:

- پنتسترها از نام میزبان‌ها برای شناسایی سرویس‌های حیاتی سازمان استفاده می‌کنند.
- این کار به آن‌ها کمک می‌کند تا سطح حمله (Attack Surface) سازمان را به طور کامل درک کنند.

ب) تست مقاومت سرویس‌ها:

- **VPN** : پنتسترها تست می‌کنند که آیا سرویس VPN در برابر حملات **Password Spraying** مقاوم است یا خیر.
- **Citrix** : آن‌ها بررسی می‌کنند که آیا سرویس‌های Citrix در برابر نفوذ و Breakout (خروج از محیط Citrix) محافظت شده‌اند.
- **Microsoft Exchange** : پنتسترها تست می‌کنند که آیا سرویس‌های ایمیل در برابر حملات به نقاط پایانی (Endpoints) مانند autodiscover و owa مقاوم هستند.
- **SSO/ADFS** : آن‌ها بررسی می‌کنند که آیا سرویس‌های SSO و ADFS در برابر سوءاستفاده محافظت شده‌اند.

ج) ارزیابی امنیت اعتبارنامه‌ها:

- پنتسترها از نام میزبان‌ها برای شناسایی سرویس‌هایی که ممکن است از رمزهای عبور ضعیف استفاده کنند، استفاده می‌کنند.
- آن‌ها تست می‌کنند که آیا سازمان از **MFA** (احراز هویت دومرحله‌ای) برای محافظت از سرویس‌های حیاتی استفاده می‌کند.

د) گزارش دهی و بهبود امنیت:

- پنتسترها از اطلاعات نام میزبان‌ها برای تهیه گزارش‌های دقیق درباره نقاط ضعف سازمان استفاده می‌کنند.
- این گزارش‌ها به سازمان کمک می‌کند تا امنیت سرویس‌های حیاتی خود را بهبود بخشند.

مثال عملی با جزئیات فنی بیشتر و دستورات

در این بخش، مثال‌های عملی را با جزئیات فنی بیشتر و دستورات مرتبط برای هکرها و پنتسترها بررسی می‌کنیم.

1. مثال برای هکرها: حمله به VPN با استفاده از Password Spraying

سناریو:

- هکر نام میزبان `vpn.example.com` را شناسایی می‌کند.
- هدف: دسترسی به شبکه داخلی سازمان از طریق VPN.

مراحل حمله:

1. شناسایی سرویس VPN :

- هکر از ابزارهایی مانند **Nmap** برای شناسایی پورت‌های باز و سرویس‌های در حال اجرا استفاده می‌کند.
- دستور **Nmap** :

```
nmap -sV -p 443 vpn.example.com
```

- این دستور پورت 443 (معمولاً برای VPN استفاده می‌شود) را اسکن می‌کند و نسخه سرویس را شناسایی می‌کند.

2. تهیه لیست کاربران و رمزهای عبور رایج:

- هکر لیستی از کاربران احتمالی (مانند `admin, user1, user2`) و رمزهای عبور رایج (مانند `Password123!, Welcome1, Admin123`) تهیه می‌کند.

3. اجرای حمله Password Spraying :

- هکر از ابزار **Hydra** برای اجرای حمله Password Spraying استفاده می‌کند.
- دستور **Hydra** :

```
hydra -L users.txt -P passwords.txt vpn.example.com http-post-form  
"/login:username=^USER^&password=^PASS^:Invalid credentials"
```

- این دستور حمله Password Spraying را روی سرویس VPN اجرا می‌کند.
- `users.txt`: فایل حاوی لیست کاربران.
- `passwords.txt`: فایل حاوی لیست رمزهای عبور.

- اگر احراز هویت دومرحله‌ای (MFA) فعال نباشد، هکر می‌تواند به شبکه داخلی دسترسی پیدا کند.

4. دسترسی به شبکه داخلی:

- پس از موفقیت‌آمیز بودن حمله، هکر از ابزارهایی مانند **OpenVPN** یا **Cisco AnyConnect** برای اتصال به VPN استفاده می‌کند.
- دستور اتصال به VPN:

```
openvpn --config client.ovpn
```

- این دستور به هکر اجازه می‌دهد به شبکه داخلی سازمان متصل شود.

2. مثال برای پنتسترها: تست نفوذ به سرویس Citrix

سناریو:

- پنتستر نام میزبان citrix.example.com را شناسایی می‌کند.
- هدف: بررسی آسیب‌پذیری‌های سرویس Citrix و ارائه گزارش.

مراحل تست نفوذ:

1. شناسایی سرویس Citrix:

- پنتستر از ابزار **Nmap** برای شناسایی پورت‌های باز و سرویس‌های در حال اجرا استفاده می‌کند.
- دستور Nmap:

```
nmap -sV -p 80,443 citrix.example.com
```

- این دستور پورت‌های 80 و 443 (معمولاً برای Citrix استفاده می‌شوند) را اسکن می‌کند.

2. بررسی آسیب‌پذیری‌های Citrix:

- پنتستر از ابزار **Metasploit** برای بررسی آسیب‌پذیری‌های Citrix استفاده می‌کند.
- دستورات Metasploit:

```
Msfconsole
```

```
use auxiliary/scanner/citrix/citrix_enum
```

```
set RHOSTS citrix.example.com
```

```
run
```

- این دستورات آسیب‌پذیری‌های Citrix را بررسی می‌کنند.

3. تست Breakout (خروج از محیط Citrix):

- اگر Citrix میزبان برنامه‌های تک‌کاربره باشد، پنتستر تست می‌کند که آیا امکان Breakout وجود دارد یا خیر.

دستورات Breakout:

- پنتستر از اسکریپت‌های سفارشی یا ابزارهایی مانند **Citrix ADC Exploit** استفاده می‌کند.
- مثال:

```
python citrix_adc_exploit.py -t citrix.example.com
```

- این اسکریپت سعی می‌کند از محیط Citrix خارج شده و به سیستم میزبان دسترسی پیدا کند.

4. تهیه گزارش:

- پنتستر یافته‌های خود را در گزارش ثبت می‌کند.
- مثال گزارش:

یافته‌ها:

- سرویس Citrix در `citrix.example.com` در معرض آسیب‌پذیری‌های شناخته‌شده است.
- امکان Breakout از محیط Citrix وجود دارد.

توصیه‌ها:

- به‌روزرسانی Citrix به آخرین نسخه.
- فعال‌سازی MFA برای دسترسی به Citrix.
- نظارت بر لاگ‌ها برای شناسایی فعالیت‌های مشکوک.

جمع‌بندی:

- هکرها** از اطلاعات نام میزبان‌ها برای شناسایی اهداف پریسک، اجرای حملات هدفمند، و نفوذ به شبکه‌های داخلی استفاده می‌کنند.
- پنتسترها** از این اطلاعات برای شناسایی سطح حمله، تست مقاومت سرویس‌ها، و بهبود امنیت سازمان استفاده می‌کنند.
- در هر دو حالت، نام میزبان‌ها نقش کلیدی در شناسایی سرویس‌های حیاتی و نقاط ضعف سازمان ایفا می‌کنند.

- **هکرها** از ابزارهایی مانند **Nmap, Hydra** و **OpenVPN** برای شناسایی و نفوذ به سرویس‌های حیاتی مانند VPN و Citrix استفاده می‌کنند.
- **پنتسترها** از ابزارهایی مانند **Nmap, Metasploit** و اسکریپت‌های سفارشی برای تست نفوذ و بررسی آسیب‌پذیری‌ها استفاده می‌کنند.
- در هر دو حالت، دستورات و ابزارهای استفاده‌شده به شناسایی و سوءاستفاده از نقاط ضعف کمک می‌کنند.

دوستان از ما میتوانیم از طریق Log Stealer ها به شبکه نفوذ کنیم :

Log Stealer یک تکنیک پیشرفته است که در آن مهاجمان (هکرها) از فایل‌های لاگ (Log Files) سیستم‌ها و سرویس‌های شبکه برای جمع‌آوری اطلاعات حساس و نفوذ به شبکه استفاده می‌کنند. این روش می‌تواند به مهاجمان کمک کند تا اعتبارنامه‌ها، فعالیت‌های کاربران، و سایر اطلاعات حیاتی را به دست آورند و از آن‌ها برای **Lateral Movement** در شبکه استفاده کنند. در ادامه، این روش را با جزئیات بیشتر و مثال‌های عملی توضیح می‌دهیم.

1. هدف از Log Stealer در نفوذ به شبکه

- **استخراج اعتبارنامه‌ها:** لاگ‌ها ممکن است حاوی نام کاربری و رمزعبور باشند، به ویژه اگر سیستم‌ها به درستی پیکربندی نشده باشند.
- **شناسایی فعالیت‌های کاربران:** لاگ‌ها می‌توانند اطلاعاتی درباره فعالیت‌های کاربران، مانند دسترسی به فایل‌ها یا اجرای دستورات، ارائه دهند.
- **شناسایی ساختار شبکه:** لاگ‌ها ممکن است حاوی اطلاعاتی درباره سایر سیستم‌ها، سرویس‌ها، و ارتباطات شبکه باشند.
- **Lateral Movement در شبکه:** با تحلیل لاگ‌ها، مهاجمان می‌توانند اطلاعاتی درباره سایر سیستم‌ها یا سرویس‌های شبکه به دست آورند و از آن‌ها برای **Lateral Movement** در شبکه استفاده کنند.

2. مراحل Log Stealer برای نفوذ به شبکه

2.1. شناسایی هدف

- مهاجمان سیستم‌ها یا سرویس‌هایی را که احتمالاً لاگ‌های حساسی تولید می‌کنند، شناسایی می‌کنند.
- **مثال:** وب سرورها، سرورهای پایگاه داده، سیستم‌های احراز هویت.

2.2. دسترسی به فایل های لاگ

- مهاجمان ممکن است از روش های مختلفی برای دسترسی به فایل های لاگ استفاده کنند:
 - دسترسی مستقیم: اگر مهاجم به سیستم دسترسی داشته باشد، می تواند مستقیماً به فایل های لاگ دسترسی پیدا کند.
 - سوءاستفاده از آسیب پذیری ها: استفاده از آسیب پذیری هایی مانند Directory Traversal برای دسترسی به فایل های لاگ.
 - جعل درخواست ها: ارسال درخواست های جعلی به سرویس ها برای تزریق اطلاعات حساس به لاگ ها.

2.3. استخراج اطلاعات حساس

- مهاجمان فایل های لاگ را تحلیل کرده و اطلاعات حساس مانند اعتبارنامه ها، آدرس های IP، و فعالیت های کاربران را استخراج می کنند.

2.4. Lateral Movement در شبکه

- با استفاده از اطلاعات به دست آمده، مهاجمان می توانند به سایر سیستم ها یا سرویس های شبکه دسترسی پیدا کنند و Lateral Movement انجام دهند.

3. مثال عملی: نفوذ به شبکه با استفاده از Log Stealer

سناریو: نفوذ به شبکه از طریق سرقت لاگ های وب سرور

1. شناسایی هدف: مهاجم یک وبسایت با آدرس `example.com` را هدف قرار می دهد.
2. دسترسی به فایل های لاگ:
 - مهاجم از آسیب پذیری Directory Traversal برای دسترسی به فایل های لاگ وب سرور استفاده می کند.
 - دستور:

```
curl http://example.com/../../../../var/log/apache2/access.log
```

- این دستور سعی می کند به فایل `access.log` دسترسی پیدا کند.
- 3. استخراج اطلاعات: مهاجم فایل های لاگ را تحلیل کرده و اطلاعات حساس مانند اعتبارنامه ها یا فعالیت های کاربران را استخراج می کند.

4. Lateral Movement در شبکه:

- مهاجم از اعتبارنامه‌های به دست آمده برای دسترسی به سایر سیستم‌های شبکه استفاده می‌کند.
- مثال: استفاده از ابزارهایی مانند **Psexec** برای اجرای دستورات روی سیستم‌های دیگر:

```
psexec \\target-system -u admin -p password cmd.exe
```

4. دفاع در برابر Log Stealer

4.1. محدود کردن دسترسی به لاگ‌ها

- اطمینان حاصل کنید که فقط کاربران مجاز می‌توانند به فایل‌های لاگ دسترسی داشته باشند.
- مثال: تنظیم مجوزهای فایل‌های لاگ در لینوکس:

```
chmod 600 /var/log/auth.log
```

4.2. رمزنگاری لاگ‌ها

- لاگ‌ها را رمزنگاری کنید تا در صورت سرقت، اطلاعات قابل استفاده نباشند.
- مثال: استفاده از ابزارهایی مانند **Logrotate** همراه با رمزنگاری.

4.3. نظارت بر دسترسی به لاگ‌ها

- دسترسی به فایل‌های لاگ را نظارت کرده و هرگونه فعالیت مشکوک را بررسی کنید.
- مثال: استفاده از ابزارهای نظارتی مانند **OSSEC** یا **Splunk**.

4.4. به‌روزرسانی سیستم‌ها و سرویس‌ها

- سیستم‌ها و سرویس‌ها را به‌روز نگه دارید تا از آسیب‌پذیری‌هایی که ممکن است منجر به سرقت لاگ‌ها شوند، جلوگیری کنید.

5. نکات

1. **Log Stealer** : سرقت فایل‌های لاگ برای استخراج اطلاعات حساس و نفوذ به شبکه.
2. **اهداف** : اعتبارنامه‌ها، فعالیت‌های کاربران، ساختار شبکه.
3. **روش‌ها** : دسترسی مستقیم، سوءاستفاده از آسیب‌پذیری‌ها، جعل درخواست‌ها.
4. **Lateral Movement** : استفاده از اطلاعات به دست آمده برای دسترسی به سایر سیستم‌ها.
5. **دفاع** : محدود کردن دسترسی، رمزنگاری لاگ‌ها، نظارت بر دسترسی، به‌روزرسانی سیستم‌ها.

جمع‌بندی:

- **Log Stealer** یک تکنیک خطرناک است که می‌تواند منجر به نفوذ به شبکه و Lateral Movement شود.
- با محدود کردن دسترسی، رمزنگاری لاگ‌ها، و نظارت بر فعالیت‌ها، می‌توان از این نوع حملات جلوگیری کرد.

ارتباط با نویسنده :

<https://www.x.com/kavehxnet>

برای آموزش‌های بیشتر ما را شبکه‌های اجتماعی دنبال کنید :

Telegram : [@TryHackBox](https://t.me/TryHackBox)

YouTube : [@TryHackBox](https://www.youtube.com/TryHackBox)